

통 보

1. 제 목 : 공개서버 운영 및 관리에 관한 사항

2. 관계기관 : XXXX병원

3. 내 용

가. 업무개요

우리 공단은 외부인에게 공개할 목적으로 공단 홈페이지 등 공개서버를 내부망과 분리된 영역(DMZ)에 설치·구축하여 운영하고 있습니다.

나. 관계법령 및 판단기준

「정보보안업무 처리지침」 제23조(웹서버 등 공개서버 관리)에서는 공개서버에 접근할 수 있는 사용자 계정을 제한하고, 불필요한 계정을 삭제하며, 비공개자료나 개인정보가 유·노출되거나 위·변조되지 않도록 보안조치를 취해야 한다고 규정하고 있습니다.

또한 제24조(사용자계정 관리)에서는 시스템 관리자가 로그인 실패 #회 이상 발생 시 접속을 중단하도록 설정하고, 퇴직자 또는 보직 변경자의 계정을 신속히 삭제하도록 규정하고 있으며, 제25조(접근기록 관리)에서는 사고 발생 시 추적 등을 위해 접속 성공·실패 등 접근기록을 #년 이상 보관해야 한다고 명시하고 있습니다.

한편 「국가 정보보안 기본지침」에서는 기관 인터넷망의 구축 등에 대해 보안성 검토를 실시하도록 규정하고 있으므로, 기관 인터넷망을 이용한 정보 시스템 구축·운영 시에는 보안성 검토 및 관련 보안조치를 사전에 이행하여야 합니다.

다. 감사결과 확인된 문제점

그런데 XXXX병원에서 운영 중인 공개 정보시스템을 확인한 결과, 일부 공개 정보시스템은 보안성 검토를 실시하지 않은 상태에서 운영되고 있으며, [표]와 같이 내부업무용 시스템이 DMZ에 위치하여 외부에서 접근 가능한 상태이며, 인증서 만료로 인한 비암호화 통신 사용과 접근기록 및 계정관리 미흡 등으로 인해 침해사고(해킹) 발생의 위험이 있는 사실을 확인하였습니다.

[표] XXXX병원 공개서버 운영 실태

구분	주요 내용(운영 현황)	확인된 문제점	조치 필요
서버 운영구조			
보안성 검토 절차			
통신보안			
접근기록(로그) 관리			
계정 관리			

(자료: XXXX병원 제공자료 재구성)

4. 관계기관 의견

XXXX병원에서는 감사결과를 수용하여 별다른 의견을 제시하지 않았습니다.

5. 조치할 사항

○ XXXX병원장은

- 공개 정보시스템의 사용 목적 및 운영 구조를 재검토하여, 내부업무시스템이 DMZ에서 운영되지 않도록 서버 위치를 조정하는 등 보안 취약사항에 대한 조치를 하여 주시기 바랍니다. (통보)